

Assignment 1

Melvin Viado

Cybersecurity, Durham College

MGMT1216: Security Auditing and Governance

Jerrard Gaertner

February 15, 2026

Healthcare and Hospital

Introduction

Healthcare Company X is a healthcare provider with a highly regulated IT environment and dependent on electronic records and connected devices. The audit plan of Company X must focus on privacy and regulatory compliance. Key characteristics include full-day healthcare operations where downtime can affect patient treatment and safety, workflows, and general revenue. Some of the information stored and processed on electronics are used for health records, pharmacy, and billing systems that can come from multiple vendors and cloud providers.

Healthcare Company X uses their Electronic Health Record Platform, Picture Archiving and Communication System, Laboratory Information System, Electronic Prescribing, and Medication Administration Systems. These technologies are provided by a combination of on-premises data centers, virtualized servers, and Active Directory Domain Services. End devices in Company X include monitors, infusion pumps, and other medical devices involved in the network and often running on old operating systems.

In terms of the healthcare industry trends, the attack surface is increased due to the expansion of remote monitoring, use of digital information, and patient portals. Company X relies on some of its electronic health record technologies to the cloud which they depend on their used security models. Due to past breaches and outages, healthcare companies have increased focus on cybersecurity and resilience while more frequently performing risk assessments. Company X is a Canadian company in Ontario that complies to the rules and regulations provided by the Personal Information Protection and Electronic Documents Act (PIPEDA) and the Provincial Health Information Privacy Laws (PHIPA).

An example of a well-known failure was the outage of an Oracle Health Electronic Health Record System at Community Health Systems which forced many hospitals to resort to physical records on April 28, 2026. The impact of AI has been growing and could have been used for failure prevention and remediation for Oracle Health EHR. AI could also be used to decision support, and operational optimization, which may also introduce model-risk and other concerns for security auditors. There are still many issues for the applicability of AI from issues relating to Personal Health Information handling and data minimization which engineers aim to resolve in the future.

Preliminary Risk Assessment

Company X operates under strict provincial laws, handles sensitive health data, and provides health-critical services unlike normal commercial companies, proving that Company X faces healthcare specific risks. Regulatory non-compliance can take place if Company X does not document new integrations where formal threat-risk assessments are required in the electronic health record infrastructure of Ontario. Company X also faces the risk that medical devices tend to have older operating systems or protocols which can make it difficult to update or patch. Updating such systems are a common security measure for such companies.

The importance of the business-continuity of Healthcare Company X is crucial as it is dependent on patient-safety. Healthcare Company X can experience operationally unwanted events such as missed diagnoses and delayed surgeries without full-uptime services. Complex

healthcare workflows and processes can also create clinical risks, especially when many technologies are involved. Additionally, Healthcare X will have more complex communication with Ontario Health and other partners from their incident response team compared to a normal private company. Threat-risk management and documented risk treatment is required from Company X for PHIPA and Ontario Health Electronic Health Record standards. Professional regulators may review its practices that may suggest unsafe care where any breach can have a greater impact on contractual consequences compared to regular private companies.

In terms of financial risks, IT failures can negatively affect funding flows where funding depends on accurate submission of clinical and administrative data. Failure to comply to healthcare security program requirements can result in Company X's ability to participate in digital-health programs moving forward. Company X will experience significant costs for remediation from privacy and cybersecurity incidents if not careful with their practices.

Specific Risk Assessment

Company X faces a greater IT risk from its customer data cloud migration, mandatory EHR integration, and PHIPA compliance obligations. Company X runs the risk of exposing Personal Health Information from cloud misconfigurations that may come from lack of provider certifications and data labeling in their cloud environments. Government EHR integration can be a risk with data corruption if cloud interfaces fail to validate. Combining cloud with on-premises setups can create ransomware issues from the use of outdated, unsupported hardware or software components including routers and healthcare controllers.

The process of migrating customer data to the cloud can increase outage risks from testing and updates, which can stop HER access and disrupt patient care. On top of this, dependency on the cloud for 24/7 clinical availability means that incidents caused by vendors can result in failure to report to provincial bodies including Ontario Health.

Staff requiring access to the newly migrated cloud data from new portals face the challenge of retraining effective use of these portals. This increases the chance for successful phishing attacks and improper sharing of sensitive information in the intensive care environment of Company X. Awareness programs must cover PHIPA rules specific to the usage of the cloud emphasizing the great impact of non-compliance.

Company X will face a financial cost of migration to the cloud on top of the cost associated with cloud auditing which puts pressure on the Company X's budget. Company X may also risk experiencing vendor lock-in which impacts cost optimization in parallel to the costs of mandatory provincial integrations. Breach fines or remediation from cloud incidents can also negatively affect reimbursements under PHIPA.

Type of Audit and Audit Objectives

The main objective for a statutory financial audit on Company X in Ontario, Canada, is to show that the financial statements are fair in all aspects while considering the controls implemented in its information technology environment over important financial systems. This is important due to the recent cloud migration of customer data and mandated electronic health record integration of Company X.

In terms of the system in scope, it involves the billing systems that interact with the new cloud platform and government-mandated electronic health record system that helps generate the revenue for Company X. The company needs to ensure completeness and accuracy in billings and receivables relating to the cloud-based customer data platform. The systems that are excluded in the scope are clinical systems and non-financial human resources systems unless they feed financial data.

Processes within the scope include revenue from patient services relating to electronic health record data and cloud billing modules. Revenue can be accounts receivable, accounts payable, and provincial funding that is affected by cloud migration. Another process is the generation of automated reports from the cloud and electronic health record integrations.

The location for the audit will primarily focus on the corporate headquarters of Company X and the central information technology data center in Ontario. Company X has many clinic sites, so we will sample 2 clinic sites and capture billing and electronic health record data along with remote cloud controls data from the providers.

In our audits on Company X, we must do revenue testing from EHR and the cloud while evaluating the provincial receivables. We will assess cloud access controls, change in management, and perform integrity check. Lastly, we will provide PHIPA financial data handling evidence for compliance. In terms of what is nice to do, we will determine the payroll cycle, perform disaster recovering testing, and perform penetration testing on the cloud data.

Resources, Timelines, Scheduling, Cost, Administrative Matters

The team members will include the audit partner to oversee quality, audit manager to manage fieldwork, senior auditor for substantive testing, IT audit specialist to test the cloud, and a junior auditor for support with sampling. The tools and technology used will include CaseWare for auditing software, Audit Command Language Analytics for specialized data analytics, a VPN for secure access to the cloud, and MS Teams for real-time team coordination and collaboration.

We will introduce a cloud security consultant given that the migration process and its reports are inadequate. Although, recruiting this consultant is not mandatory for this scope but helps create a justified opinion on information technology general controls testing.

For the time budget and timeline, we will have a total of 650 hours over 4 months and provide \$169K in compensation for the entire team based on varied hourly rates. In the first 2 weeks, we will allocate the time for planning and risk assessment. From weeks 3 to 7, we will perform control testing, collect sampling results, and create a management letter draft to satisfy IT general controls testing and substantive sampling. From weeks 8 to 10, we will adjust and finalize analytics for reviews and clearance. Lastly, the last 2 weeks will involve presenting to the board of the reports and have closure.

The report will deliver a statutory opinion, a management letter, and an Audit Group Memo. The statutory opinion will be a report on company financials with audit information on revenue and electronic health records. The management letter will be IT general control test findings and PHIPA evidence recommendations that will be presented to the audit committee. Lastly, the audit group memo is a summary of the risk coverage that relies on the cloud security reports.

Possible Challenges and Audit Execution Risks

There are several possible challenges and obstacles that could interfere with the audit of the financial statements of healthcare company X. One concern is being provided access to the migrated cloud platform and the government-mandated electronic health records systems as the audit team. Healthcare providers often impose strict security measures to protect patient information which can delay fieldwork and testing of financial data.

Another challenge is that auditors can be disruptive to patient care, especially during busy periods. The clinical staff can provide incomplete responses or postpone interviews during sampling and testing operations. Coordinating across multiple hospital sites can also provide challenging due to various schedules and travel logistics in Ontario. Additionally, reports from third-party cloud providers can be less effective if the documents become outdate or incomplete after migrating electronic health records.

The audit team should secure access agreements and non-disclosure commitments in advanced to best mitigate these issues. Site visits should be scheduled during off-peak hours such as early morning or weekends to minimize interference with delivery of healthcare services. Building rapport with the hospital staff can increase cooperation while using remote tools to eliminate physical visits.

Delivery deadlines for third-party vendor reports should be set. Regular progress check-ins with the audit committee bi-weekly can help spot evidence of delays early to make room for adjustments to the timeline without fully compromising the main deadline. This is necessary to keep the audit on track while respecting the healthcare environment.

CHAIN OF FAST-FOOD RESTAURANTS

The fast-food restaurant chain Company Y prioritizes service delivery, affordability, and consistency across locations. Company Y provides a standardized menu, assembly-line operations, and high-volume delivery in locations of high-traffic areas. Company Y aims to provide consistent quality, pricing, and operations for customer loyalty alongside extended hours and low labour costs.

The technologies you will find with Company Y is point-of-sale systems that handle orders, payments, and inventory tracking. With Company Y's locations, they use drive-thru timers, kitchen displays, and self-service kiosks for efficient operations. Company Y also uses delivery platforms DoorDash and UberEats for food deliveries and ordering in advanced.

The trends for the fast-food industry have driven companies like Company Y to use ordering applications and aggregators. Increases in automation of the supply chain and service delivery is also a trend as it reduces food waste and food discarded. Lastly, a trend is that there are increases in health-focused menu items to attract a larger market and demographics. Company Y considers labor laws that covers minimum wage and overtime for staff. They also have health inspections that focus on cross-contaminations while data privacy laws apply to customer apps under GDPR.

The AI drive-thru pilot from McDonalds is a notable failure as it struggled with order interpretation, menu suggestions, and noise issues which led to quick termination. Although AI can be used in fast-food restaurants for data analytics on menu performance and optimizations in inventory and labor. The audit for Company Y should verify point-of-sale data integrity, supply chain controls, and an AI system for error and bias detection. The audit will also include franchise compliance, cybersecurity, and wage adherence.

Preliminary Risk Assessment

The risk that fast-food restaurant chain Company Y faces in terms of technology are high-volume and real-time transactions processed in busy environments. Kitchen display systems linked to inventory trackers can have the risk of failing during peak hours, where a single point in failure can pause assembly lines and spoil stock. Company Y demands constant uptime unlike office firms with less urgency for transactions.

In terms of operational risk, Company Y runs the risk of contamination outbreaks if a single tainted batch is distributed. This can cause costs associated with recalling these batches across many sites. High-turnover frontline crews managing cash and food safety pose a risk to human resources. Lack of thorough training for teenagers and part-timers increases the risk of cross-contamination or theft through under-ringing sales. Inconsistencies in scheduling software for varying demand result in long-term understaffing, which slows down service and increases the risk of accidents from hurried kitchen work. The skilled workforces in other industries contrast with this labor instability.

Thin margins on low-cost products and regulatory scrutiny are the sources of legal and financial risks. Violations result in closures or fines that are out of proportion to site income. While delivery platform commissions reduce 20–30% of orders, franchise disputes over royalty

calculations based on manipulated sales data lead to litigation drains. Beyond typical contract risks, these exposures increase under food-specific liabilities such as allergen failures.

Specific Risk Assessment

Fast-food chains using both digital point-of-sale logs and paper-based inventory sheets create challenges in aligning the financial records. Paper records at each location can be lost during high turnover periods, while digital records can have mismatched formats which also loses sales. This process of combining digital and paper copies fraud such as underreported cash and false digital information.

Food delivery tracking suggests poisoning liability where stock that has aged is not removed and is given to customers. Suppliers send stock with expiry dates on them, but manual checks can miss these dates under high turnover where items that are spoiled are not tracked. Company Y uses RFID tags on stock for real-time age flags to remove expired stock to prevent poisoning.

Fast-food restaurant chains using varied technologies that are unsophisticated pose an audit risk because the data collected for the audit is fragmented. Auditors will face incomplete data extraction that require manual reconciliation when handling unsophisticated systems and devices. An example of this is older kiosks or unpatched registers that lack encryption that modern devices would have, inviting sensitive data leaks in busy hours.

Type of Audit and Audit Objectives

The audit aims to confirm that the financial statements of fast-food restaurant chain Company Y present a fair view of the position and performance of Company Y under the United States accounting standards. Auditors will check the internal controls over financial reporting while giving their opinion on whether the given statements do not have major errors or fraud. The scope is closed to financial matters, avoiding details about operation relating to the quality of the menu or staff training.

Boundaries of the audit are financial statements that contain revenue from delivery, inventory, royalties, and payment systems from all locations. Key processes are sales from point-of-sale setups and supply chain costing. The audit will sample 20 of Company Y's franchise sites chosen based on the variety of technology used and the volume of its sales.

The audit will flag control weaknesses that could lead to inaccuracies in the financial statements. Management will get letters privately on the gaps of implemented controls such as inaccurate digital expiry logs. The auditing committee will receive updates along the audit on findings relating to the various technologies used.

Resources, Timelines, Scheduling, Cost, Administrative Matters

The audit team will be a collection of lead partners, seniors skilled in revenue testing and inventory counting, staff for fieldwork, and IT specialists for point-of-sale data extraction. The provided skills will be used to assess food cost variance and control testing over expiry logs. The tools and technology required are auditing software, drives for site data, mobile apps for sampling, and computers or laptops.

We will take 4 weeks for planning, 12 weeks for fieldwork across 20 sites, and 4 weeks for reporting which totals to 5 months. We aim to achieve risk assessment by week 4, finalize the preparations to perform tests by week 12, collect test results by week 20, and draft a report by week 22. A large budget will be attributed to the 20 sites that requires testing performed by the audit team, taking into consideration the travel costs and the amount of testing hours allocated.

The audit team will deliver an opinion letter on the financial statements and the internal controls for the regulators. Additionally, management will receive a private letter on the gaps found in the various technology used across all the sites. For each of the restaurants, there will be administration that manages site access, non-disclosure agreements for company information, and travel logistics for various locations.

Possible Challenges and Audit Execution Risks

Fast-food restaurant chain audits face obstacles related to their scattered locations. Managers may limit access to sites during peak hours which can slow fieldwork schedules by weeks. Mitigation of this challenge can include scheduling planned meetings on the site schedule and mandating cooperation of the site while setting penalties for delays.

As mentioned before, the use of various technologies can create mismatches in the collected data. Manual fixes can require long hours of work due to point-of-sale devices exporting incomplete data. Auditors can mitigate this challenge by identifying issues with sites showing high-risk early on. Then they can conduct a walkthrough of the IT systems for those sites to learn ways to properly handle their data.

Other challenges can include travel costs for various locations and high staff turnover resulting in increased failures in testing. To mitigate this challenge, video interviews can be conducted for proof of training and clustering site visitation to efficiently test them.